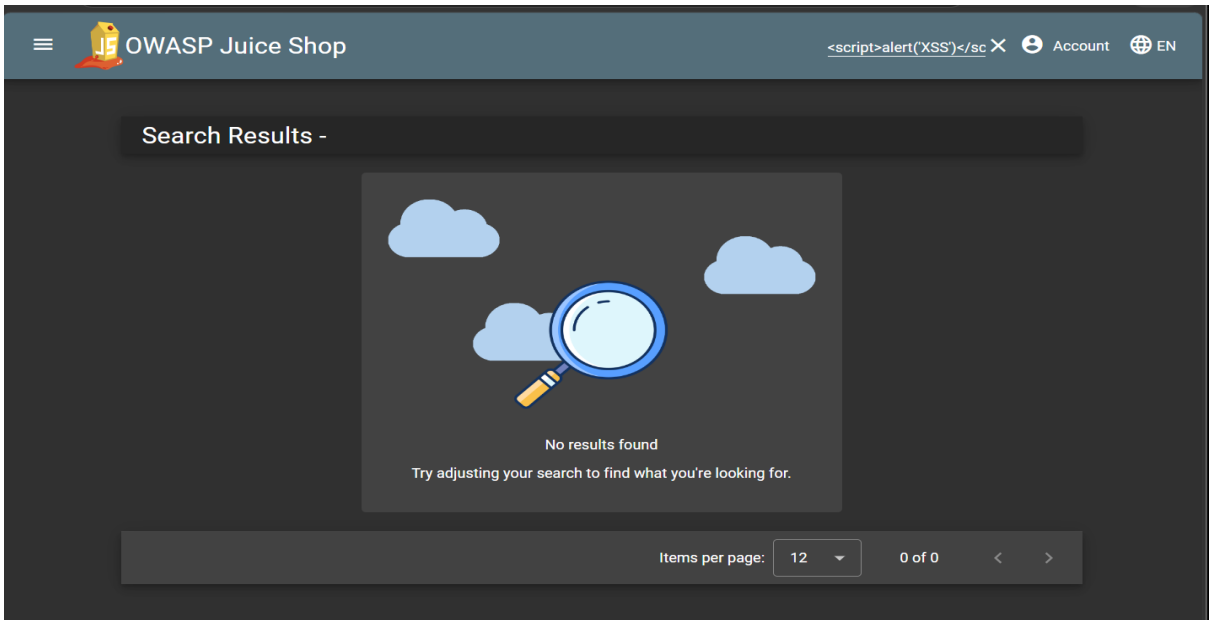
XSS payloads on Juice Shop search box:

1 Basic alert: <script>alert('XSS')</script>



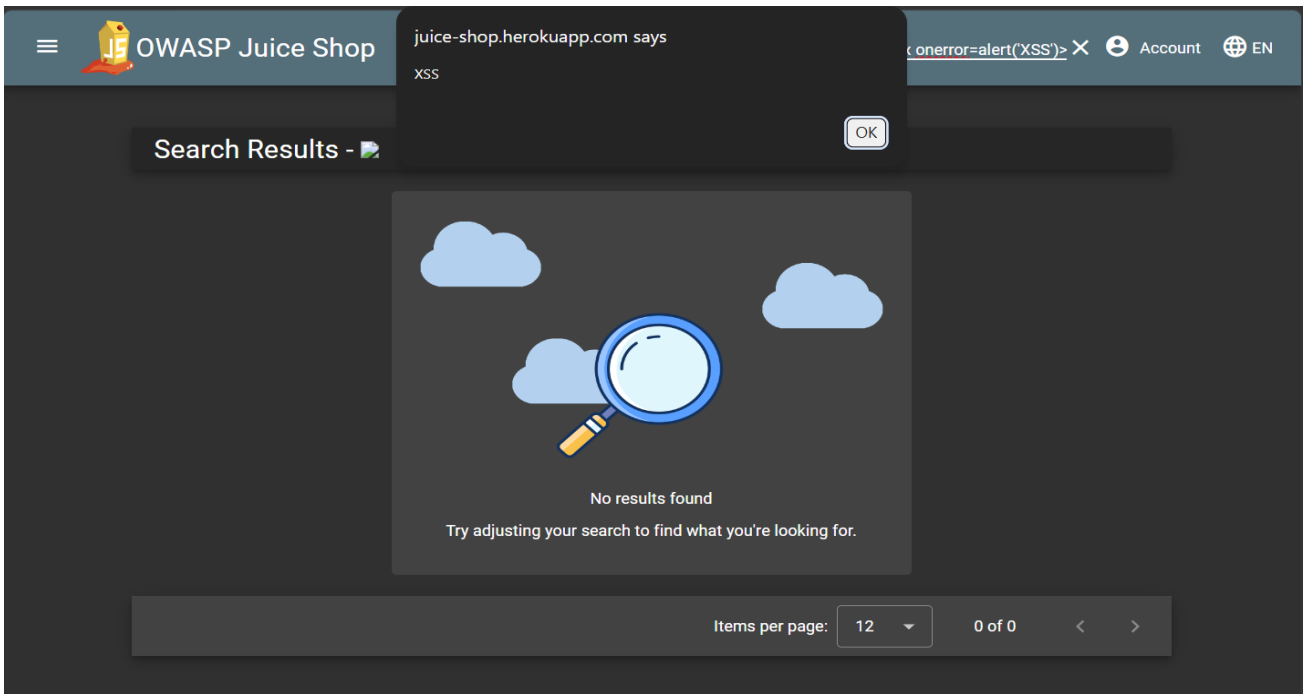
What it does:

- Executes JavaScript directly
- Shows a popup alert

Explanation:

This payload injects a script tag that executes JavaScript and displays an alert box, proving that user input is not properly sanitized.

2 Image tag: <img src=x onerror=alert('XSS')>



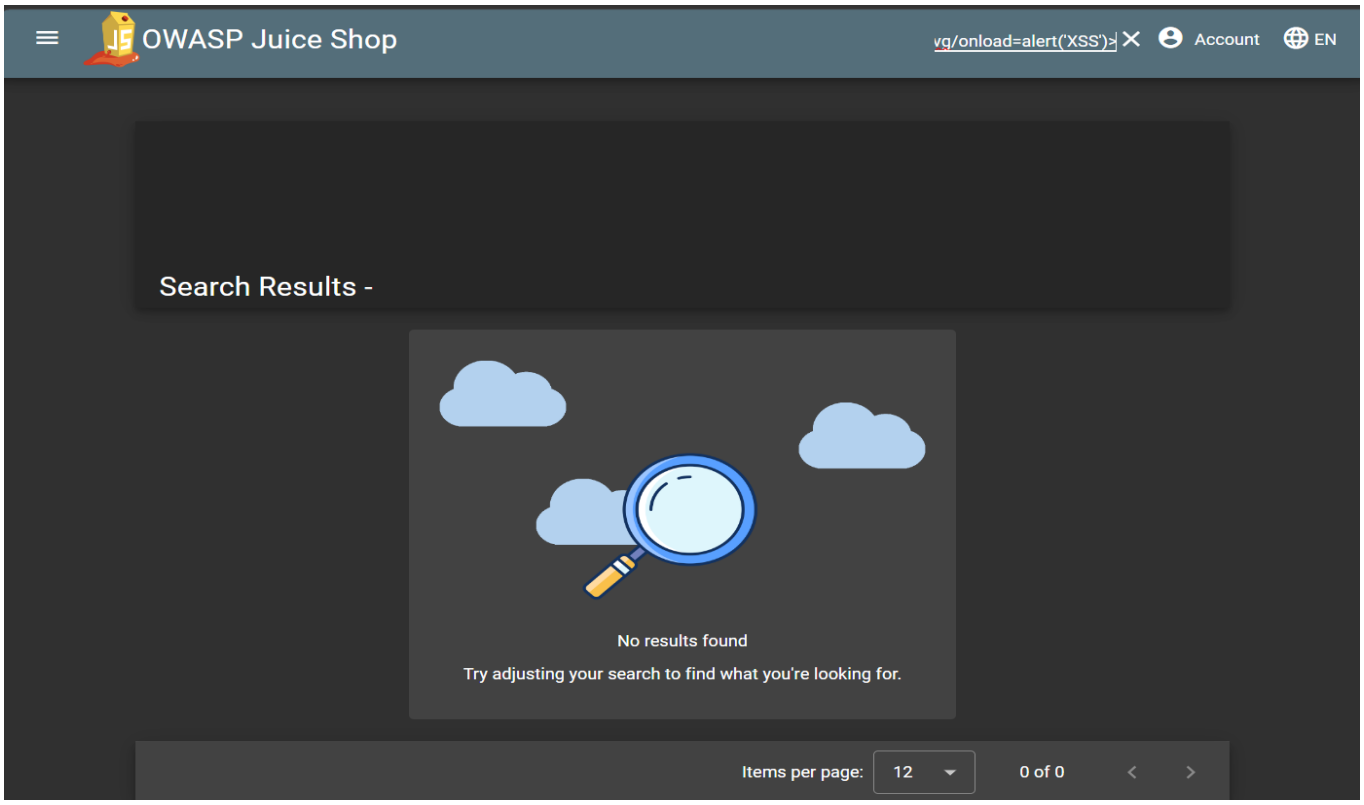
What it does:

- Tries to load invalid image (x)
- Triggers one error → runs JavaScript

Explanation:

This payload uses an image tag with an error event to execute JavaScript when the image fails to load.

3 SVG: <svg/onload=alert('XSS')>



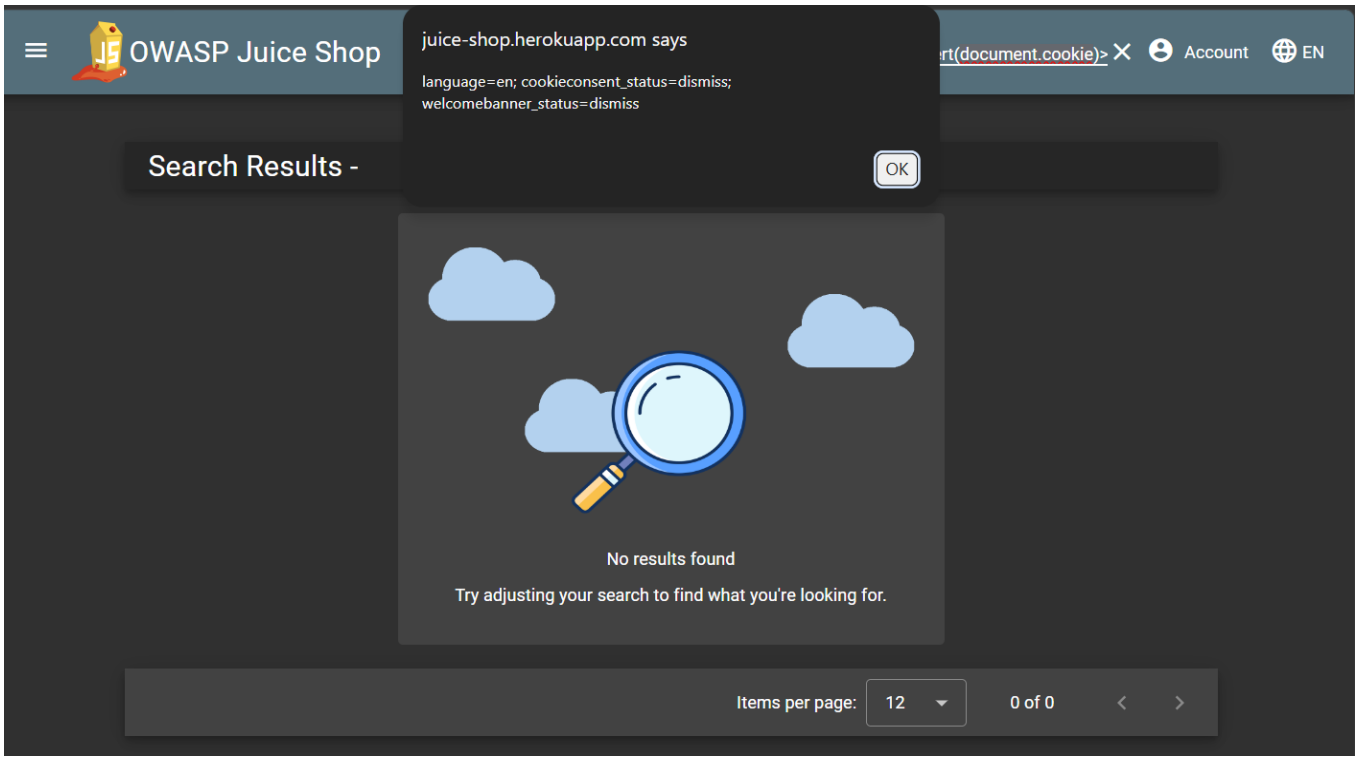
What it does:

- Uses SVG element
- Executes code when loaded

Explanation:

This payload exploits SVG tag behavior to execute JavaScript using the onload event.

4 Cookie display: <img src=x onerror=alert(document.cookie)>



What it does:

- Displays browser cookies
- Demonstrates **data theft risk**

Explanation:

This payload accesses and displays cookies, showing how attackers can steal sensitive session data.

5 DOM manipulation: <img src=x onerror="document.body.innerHTML='HACKED'">

What it does:

- Replaces entire webpage content
- Shows “HACKED”

Explanation:

This payload modifies the DOM by replacing the page content, demonstrating how attackers can deface a website.